

TokenStream CRA Cybersecurity Risk Assessment Methodology

Draft | 2026-08-26 | Product: TokenStream | Assessed version: 0.1.0

Assessment type: CRA voluntary readiness risk assessment; no EU Declaration of Conformity or CE marking.

1. Assessment Scope

This assessment covers TokenStream as a self-hosted, software-only, open-source AI orchestration and retrieval runtime. The assessed deployment model is the Docker Compose topology documented in the repository, including:

- dev-ui and the embedded config_auth registry/auth package;
- orchestrator-api;
- retrieval-api;
- ingestion-worker;
- Qdrant vector storage;
- MinIO-compatible object storage;
- SQLite-backed registry, lexical, and graph data;
- runtime provider/policy/processor/retrieval-profile snapshots;
- external model providers configured through provider records;
- optional MCP servers configured as TokenStream tools;
- optional Open WebUI only where deployed as part of the TokenStream stack.

The assessment covers TokenStream product behavior, default configuration, documented deployment assumptions, vulnerability handling, security updates, and evidence needed for CRA readiness.

Out of scope for this assessment:

- formal CE marking, EU Declaration of Conformity, and market-placement claims;
- customer or integrator applications built on top of TokenStream;
- internal security of external LLM providers, MCP servers, Qdrant, MinIO, Open WebUI, Docker Desktop, host operating systems, and reverse proxies, except where TokenStream configuration or integration choices affect TokenStream risk;
- production SaaS operation, hosting SLAs, or managed-service controls not present in the repository.

2. Assessment Metadata

Field	Value
Assessment owner	TBD: TokenStream maintainer / CRA readiness owner
Assessment date	2026-08-26
Product	TokenStream
Assessed version	0.1.0
Distribution model	Open-source, non-commercial, self-hosted software
Threat identification methodology	STRIDE
Risk estimation methodology	Likelihood x Impact
Risk formula	Risk score = likelihood score x impact score
Tooling	OWASP Threat Dragon v2.6.2, STRIDE diagram type
Threat Dragon instance	http://localhost:8081/#/
Threat Dragon model file	docs/cra/threat-dragon/tokenstream-cra-stride-threat-model.json

3. Threat Identification Methodology

Threats are identified using STRIDE:

STRIDE category	Security property
Spoofing	Authenticity
Tampering	Integrity
Repudiation	Non-repudiation and accountability
Information Disclosure	Confidentiality
Denial of Service	Availability
Elevation of Privilege	Authorization and privilege boundaries

Threat identification is performed over the Threat Dragon data-flow diagram. For each actor, process, data store, data flow, and trust boundary, assess whether any STRIDE category is

relevant. Threats should be documented with a scenario, affected asset, affected security property, existing assumptions or safeguards, likelihood, impact, treatment decision, owner, and status.

Threat Dragon is used for diagramming and STRIDE prompting. It does not define TokenStream's risk methodology; the scoring model below is the authoritative scoring method for this CRA risk assessment.

4. Risk Scoring Criteria

Risk score = Likelihood x Impact

Likelihood

Score	Definition	Assessment guidance
1	Rare	Requires exceptional conditions, privileged preconditions, or no known practical attack path in the assessed deployment.
2	Unlikely	Plausible but difficult; requires uncommon access, unusual configuration, or multiple failures.
3	Possible	Credible in normal self-hosted deployments, especially with common misconfiguration or exposed interfaces.
4	Likely	Expected to occur in realistic deployments without deliberate mitigation, or supported by known attack patterns.
5	Highly likely	Easy to trigger, internet/common-tool accessible, automated, or already observed in comparable systems.

Impact

Score	Definition	Assessment guidance
1	Negligible	No meaningful security effect; minor local inconvenience; no sensitive data or essential function affected.
2	Minor	Limited effect on a non-critical function, non-sensitive metadata, or recoverable local state.
3	Moderate	Affects one security boundary, corpus, service function, or operational workflow with contained impact.
4	Major	Exposes or compromises sensitive data, credentials, admin actions, tool execution, provider access, or essential availability in a meaningful

Score	Definition	Assessment guidance
		deployment.
5	Severe	Systemic compromise, broad data exposure, malicious code execution, cross-boundary privilege escalation, unrecoverable integrity loss, or major service unavailability.

Risk Bands

Score range	Level	Default handling
1-4	Low	Acceptable with documented rationale; monitor during normal review.
5-9	Medium	Treatment plan required unless explicitly accepted by assessment owner.
10-15	High	Mitigation or compensating control required before release/readiness sign-off, unless formally risk-accepted by accountable owner.
16-25	Critical	Must be treated before release/readiness sign-off; acceptance requires exceptional documented justification, time-bound expiry, and compensating controls.

5. Risk Treatment Options

Option	Definition	TokenStream examples
Mitigate	Reduce likelihood or impact through a control, design change, process, test, or documentation.	Add scoped API enforcement, input limits, upload validation, secret redaction, release gate, or hardening guide.
Avoid	Remove the risky feature, exposure, dependency, or deployment pattern.	Disable optional MCP server by default; remove an unsafe default public port.
Transfer or share	Shift part of the risk through explicit operator responsibility, upstream dependency responsibility, or deployment prerequisite.	Require reverse proxy TLS; document external provider responsibility; route dependency vulnerability upstream.
Accept	Keep the risk with documented rationale, owner, expiry, and	Accept a low-risk local-only dev behavior for

Option	Definition	TokenStream examples
	review trigger.	non-production use.
Monitor	Track risk without immediate change because current score is low or dependent on external evolution.	Monitor future CRA implementing acts, SBOM format requirements, or provider API changes.

6. Risk Acceptance Criteria

Risk acceptance must be explicit and documented. It must include:

- risk ID and threat scenario;
- current likelihood, impact, and score;
- reason mitigation is not currently implemented;
- accountable owner;
- expiry or next review date;
- compensating controls, if any;
- conditions that trigger reassessment;
- affected CRA requirements and evidence references.

Default acceptance rules:

- Low risks may be accepted by the assessment owner with rationale.
- Medium risks may be accepted only with a treatment backlog item or documented justification.
- High risks require accountable owner approval and a time-bound remediation or compensating control.
- Critical risks are not acceptable for release/readiness sign-off except under exceptional, documented, time-bound conditions.

7. Review And Update Triggers

The risk assessment must be reviewed and updated when any of the following occur:

- major TokenStream release or substantial architecture change;
- new externally reachable endpoint, admin function, internal service boundary, or authentication/authorization model;
- change to provider routing, model-provider configuration, MCP tool capability, or tool allowlist behavior;
- new ingestion processor, parser, source type, upload path, or object-storage behavior;

- change to corpus isolation, retrieval filters, embedding/index storage, or deletion/purge behavior;
- introduction, removal, or major version change of a critical dependency, base image, bundled service, or optional service;
- known exploited vulnerability, severe security incident, or vulnerability class affecting TokenStream assumptions;
- change to secure update, advisory, support-period, CVD, or security contact process;
- change to CRA implementing acts, harmonised standards, common specifications, or OpenChain cross-check guidance;
- support-period or end-of-support decision;
- at least annually while the assessed version or release line remains supported.

8. Relationship To Requirement Registers

This methodology follows the preliminary CRA requirement registers. The risk assessment will be used to finalize applicability and implementation rationale for:

- Annex I Part I;
- Annex I Part II;
- Article 13;
- Article 14;
- Article 31 and Annex VII;
- Article 28, Article 30, and Annex II.

The final output of the risk assessment should feed the control library, requirement-control mapping, and evidence register. Threat Dragon provides the STRIDE model and diagram evidence; this document remains the authoritative scoring and treatment methodology.

9. Threat Dragon Model

The companion Threat Dragon model is configured with STRIDE as the diagram threat methodology and is stored at docs/cra/threat-dragon/tokenstream-cra-stride-threat-model.json. The model should be imported or opened alongside this methodology when assessing individual threat scenarios.

10. Sources

- Regulation (EU) 2024/2847, Cyber Resilience Act, official EUR-Lex PDF: https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=OJ:L_202402847
- OWASP Threat Dragon Docker and local configuration documentation: <https://www.threatdragon.com/docs/install/docker.html> and <https://www.threatdragon.com/docs/configure/local.html>

- OWASP Threat Dragon model schema documentation:
<https://www.threatdragon.com/docs/development/schema.html>
- OpenChain Project CRA Compliance Requirements & Checklist:
https://github.com/OpenChain-Project/CRA-Compliance/blob/main/CRA_Checklist_Requirement_latest.md